CompTIA SecAI+ CertMaster Study — Lesson 2.1.4

# Prerequisites for Performing AI Threat Modeling

Applying threat modeling frameworks to AI systems requires a systematic approach to identifying, analyzing, and mitigating risks unique to AI-driven architectures. Before any framework can be applied effectively, practitioners must first establish a solid foundation — spanning knowledge of AI architecture, organizational security policies, regional compliance standards, and the threat modeling frameworks themselves.

# Understanding the Business Use Case

Before diving into AI-specific risks, it is critical to thoroughly understand the **existing process** that the AI system is replacing or augmenting. This means identifying how security controls will need to evolve when transitioning from a traditional system to an AI-driven solution which is a shift that often introduces new attack surfaces and data exposure points.

1

### Who Are the End Users?

Define the user population interacting with the AI system — internal employees, external customers, or automated agents and understand their trust levels.

2

### What Data Does the AI Rely On?

Identify all data inputs, training datasets, and external data sources the AI system depends on to function and generate outputs.

3

### How and Where Is Data Processed?

Map out the data flow from ingestion to inference including where processing occurs, what infrastructure handles it, and what third-party dependencies exist.

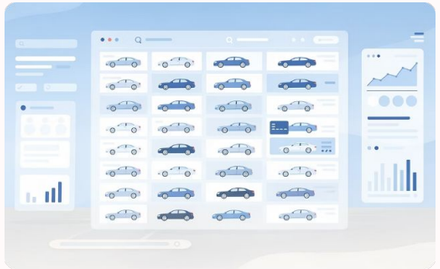
This foundational context sets the stage for a meaningful and targeted threat modeling exercise. Without it, risk identification remains incomplete.

# Business Use Case Scenario

To ground the threat modeling process in a concrete example, consider the following retail automotive AI use case. This scenario will be referenced throughout the threat modeling exercise.

## The Use Case

An AI-powered bot in the retail automotive sector assists users in buying or selling vehicles. Users can upload photos of the car and engine to receive an estimated resale value, replacing manual human assessment.



## Training Data

The bot is trained on datasets covering car types, engine manufacturing details, and historical resale values based on age and condition. It references this trained data to process user inputs and generate relevant responses.

## End Users & Process

Online customers looking to sell or purchase vehicles interact directly with the bot. The AI-driven approach minimizes or removes human involvement, replacing the traditional customer service desk interaction.

# Data and Compliance Considerations

AI systems that collect, process, and store user data introduce significant compliance obligations. Understanding the nature of that data and the regulatory environment in which the system operates is essential before modeling threats.

### Sensitive Data Inputs

The bot may collect car photos, vehicle registration numbers, driving licenses, lease agreements, and other personal or financial information, all of which require strong access controls and handling policies.

### Security Controls

Encryption during data transmission and robust input validation are foundational controls to ensure data integrity and protect user privacy throughout the AI pipeline.

### AI-Generated Output

The bot evaluates user-provided data against its internal vehicle database, performs calculations, and returns a suggested resale price — outputs that must themselves be validated for accuracy and integrity.

### Regional Compliance Requirements

Data handled by the bot may fall under multiple regulatory frameworks depending on operational geography. Organizations must identify applicable regulations before deployment.

**GDPR** — Required if operating in Europe; governs collection, processing, and storage of personal data

**AI Act** — EU regulation imposing obligations based on AI system risk classification

**CCPA** — Applies to California residents' personal data

**Local data residency laws** — May restrict where data is stored or processed

# From Use Case to Threat Modeling

The shift from a traditional human-assisted process to an AI-driven bot introduces new and expanded areas of risk. Effective threat modeling begins by mapping how data flows through the system — what is collected, how it is processed, where it is stored, and how securely it is transmitted.

## Foundational Application Security Controls

Basic security controls must be reviewed, validated, and enforced as a baseline regardless of AI involvement. These include:

**Rate limiting** — Prevent abuse and denial-of-service attacks targeting AI endpoints

**Load balancers** — Control and distribute traffic to maintain availability

**Web Application Firewall (WAF)** — Filter malicious requests before they reach the AI layer

**Network firewall rules** — Restrict unauthorized lateral movement within infrastructure

## AI-Specific Security Measures

Beyond foundational controls, AI systems require targeted measures to address risks unique to machine learning pipelines:

**Input validation** — Guard against prompt injection and adversarial inputs

**Training data integrity** — Protect against data poisoning attacks

**Model output validation** — Detect anomalous or manipulated responses

**Access controls on model assets** — Restrict who can query, update, or retrain the model

Both foundational and AI-specific controls must be implemented together and regularly evaluated. Neither set alone provides sufficient protection for an AI-driven system.

# Key Takeaways

Effective AI threat modeling is a multi-disciplinary, context-driven discipline. Before any framework is applied, the following prerequisites must be firmly in place.

## 1 Build Knowledge Foundations First

Understand AI architecture, threat landscapes, organizational security policies, regional compliance standards, and the specific threat modeling frameworks you intend to apply.

## 2 Coordinate Across Teams

Engage security, application architecture, development, infrastructure, legal, compliance, and AI architect teams. Siloed threat modeling produces incomplete results.

## 3 Understand the Business Process Before Modeling

Map the existing process, identify what changes with AI adoption, and document data flows — who collects it, how it is processed, where it is stored, and who accesses it.

## 4 Address Compliance Early

Identify applicable regional regulations (e.g., GDPR, AI Act, CCPA) for all data handled by the AI system and incorporate compliance requirements into the threat model from the start.

## 5 Layer and Validate Controls Continuously

Implement both foundational application security controls and AI-specific security measures. Regularly evaluate and validate both layers to ensure full system protection as the AI evolves.